

NAVAIR Patuxent River Naval Air Station
Department of the Navy



Request For Proposal (RFP)

ATTACHMENT (1)

Cyber Security (CS) Plan

Dated: 7 August 2025

Version 5.1

Approved by: *Amy E Sheelar*
ISSM
Information System Security Manager
PMA-266

Controlled Unclassified Information / FOUO

Below is an excerpt from the PMA-266 Cyber Security Plan (CSP). A full version of the CSP will be provided to the Contractor upon contract award. Contractors should consider the following when bidding on NAVAIR contracts:

- A. Ensure Contractor networks and applications are compatible with USN (reference SECNAVINST 5239.3B, OPNAVINST 5239.3A, CJCSI 6211.02D, DoDI 8500.2, DoDI 8510.01, NIST 800-53 and DoDI 8520.02).
- B. Ensure current industry best practices are utilized (reference SECNAV M-5239.1).
- C. Ensure ECA PKI certificates are procured and utilized for personnel supporting the contract (reference DoDI 8520.02).
- D. Ensure email is protected with PKI (reference DoDI 8520.02, CJCSI 6510.01F).
- E. Ensure DOD data is protected while at rest (reference NIST standard compliance).
- F. If delivering a system, ensure that it meets all Risk Management Framework requirements (DoDI 8500.01).
- G. Ensure there is a Cybersecurity professional with industry training to serve as a POC with Government officials (reference DoDD 8140).
- H. Ensure PKI certificates are utilized for all electronic collaboration tools (reference DoDI 8520.02).
- I. If delivering software, ensure that it meets industry standards for: validation input, integrity checking, software assurance, and supply chain risk management (reference NIST SP 800-131A).

Contractors should be familiar with DOD policies included in the References section below.

REFERENCES

CJCSI 6510.01F Information Assurance (IA) and Computer Network Defense (CND), dated February 9, 2011.

CJCSI 6211.02D Defense Information System Network (DISN): Policy, responsibilities and Processes, dated January 24, 2012.

CJCSM 6510.01B Cyber Incident Handling Program, dated July 10, 2012 (certified current December 18, 2014).

CNSS TEMPEST 01-02 CNSS Advisory Memorandum, Non-stop Evaluation Standard, dated October 2002.

CNSSI 1001 National Instruction on Classified Information Spillage, dated June 2021.

CNSSI 7000 TEMPEST Countermeasures for Facilities, dated May 2004.

CNSSP NO 22 (U) Policy on Information Assurance Risk Management for National Security Systems, dated January 2012.

DFARS 252.204-7008 Safeguarding Covered Defense Information, dated October 2016.

DFARS 252.204-7012 Safeguarding Covered Defense Information and Cyber Incident Reporting, dated December 2019.

DoDD 5000.01 The Defense Acquisition System, September 9, 2020.

DoD 5220.22-M National Industrial Security Program (NISP) Operating Manual (NISPOM), incorporating change 2, May 18, 2016.

DoDD 8140.01 Cyberspace Workforce Management, dated October 5, 2020.

DoDI 5000.02T Operation of the Defense Acquisition System, incorporating Change 10, dated December 31, 2020.

DoDI 5000.90 Cybersecurity for Acquisition Decision Authorities and Program Managers, dated December 31, 2020.

DoDI 5200.44 Protection of Mission Critical Functions to Achieve Trusted Systems and Networks (TSN), dated November 5, 2012, incorporating Change 3 dated October 15, 2018.

DoDI 5200.48 Controlled Unclassified Information (CUI), dated March 6, 2020.

DoDI 5205.13 Defense Industrial Base (DIB) Cybersecurity (CS) Activities, dated January 29, 2010, incorporating Change 2 August 21, 2019.

DoDI 8500.01 Cybersecurity, dated March 14, 2014, incorporating Change 1 effective October 7, 2019.

DoDI 8510.01 Risk Management Framework (RMF) for DoD Information Technology (IT), incorporating Change 3 dated December 29, 2020.

DoDI 8520.02 Public Key Infrastructure (PKI) and Public Key (PK) Enabling, dated May 24, 2011.

DoDI 8551.01 Ports, Protocols, and Services Management (PPSM), dated May 28, 2014, incorporating Change 1 dated July 27, 2017.

DoDI 8580.1 Information Assurance (IA) in the Defense Acquisition System, dated July 9, 2004.

DoDI 8582.01 Security of Unclassified DoD Information on Non-DoD Information Systems, dated December 9, 2019.

DTM 08-003 Directive-Type Memorandum, Next Generation Common Access Card (CAC) Implementation Guidance, incorporating change 5, October 8, 2013.

DTM 09-019 Directive-Type Memorandum, Policy Guidance for Foreign Ownership, Control, or Influence (FOCI) (May be able to amplify DoD 5220.22-M in some instances), incorporating Change 6, January 9, 2014.

DTM 09-027 Directive-Type Memorandum, Implementation of the Weapon Systems Acquisition Reform Act of 2009, incorporating change 4, January 11, 2013.

DTM 11-003 Directive-Type Memorandum, Reliability Analysis, Planning, Tracking, and Reporting (May be able to amplify DoDI 5000.02T, Operation of the Defense Acquisition System dated December 31, 2020, in some instances), incorporating change 2, January 16, 2013.

Executive Order 13691 Sharing of Cybersecurity Threat Information, dated February 13, 201

FIPS 140-3 FIPS PUB 140-3, Federal Information Processing Standards Publication, Security Requirements for Cryptographic Modules, dated March 22, 2019.

MIL-STD-461F Military Standard, Electromagnetic Emission and Susceptibility Requirements for the Control of Electromagnetic Interference, dated December 10, 2007.

MIL-STD-464C DoD Interface Standard: Electromagnetic Environmental Effects Requirements for Systems, dated December 1, 2010.

NSTISSI No. 7001 National Security Telecommunications and Information Systems Security Instruction, NONSTOP Countermeasures, dated June 15, 1994.

NIST SP 800-131A Transitions: Recommendation for Transitioning the Use of Cryptographic Algorithms and Key Lengths.

NIST SP 800-161 Supply Chain Risk Management Practices for Federal Information Systems and Organizations, dated April 2015.

NIST SP 800-171 Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations, dated February 2020. Updates as of January 28, 2021.

NIST SP 800-37 Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, revision 2, dated December 2018.

OMB A-130, App III Security of Federal Automated Information Resources (Transmittal Memorandum No. 4).

OPNAVINST 2100.2A Navy Policy and Procedures on the Issuance, Use and Management of Government Owned Cellular Phones, Personal Digital Assistants and Calling Cards, dated September 4, 2008.

OPNAVINST 5239.3A Navy Implementation of DoD Intelligence Information system Public Key Infrastructure (PKI), dated January 18, 2008.

OPNAVINST 5239.1D Navy Cybersecurity Program, July 18, 2018.

SECNAV M-5239.3 Department of the Navy Cybersecurity Manual, dated July 13, 2021.

SECNAVINST 5239.3C Department of the Navy Cybersecurity Policy, dated May 2, 2016.

SECNAVINST 5510.36B DON Information Security Program, dated July 12, 2019.

Vice Chief of Naval Operations Joint Memo Ser. N09/16U100548 (8 NOV 201

For Cybersecurity-related Policies and Issuances:

For OPNAV / SECNAV / Navy Documents see: <https://www.secnav.navy.mil/DONi/manuals-secnav.aspx>

For DoD Documents see: <https://www.esd.whs.mil/dd/#>

For MIL Documents see: <https://www.dsp.dla.mil/Policy-Guidance/>

For Classified Documents formally request from NAVAIR

For links to Cybersecurity-Related Policies and Issuances please go to:

<https://dodiac.dtic.mil/dod-cybersecurity-policy-chart/>

CS ACRONYMS

A&A	Assessment and Authorization (Replaces C&A under RMF)
ATO	Authority to Operate
C4ISR	Command, Control, Communications, Computers, Intelligence, Surveillance, and Reconnaissance
CDRL	Contract Deliverable Requirement List
CA	Certification Authority
CAC	Common Access Card
CC	Common Criteria
CIO	Chief Information Officer
CIS	Contract Instruction Services
CJCSI	Chairman of the Joint chiefs of Staff Instruction
CJSSM	Chairman of the Joint chiefs of Staff Manual
CL	Confidentiality Level
CND	Computer Network Defense
CNSSI	Committee on National Security Systems Instruction
CNSSP	Committee on National Security Systems Policy
CO	Commanding Officer
COMSEC	Communications Security
CPI	Critical Program Information
CS	Cyber Security
CTO	Computer Tasking Order
CUI	Controlled Unclassified Information
DAA	Designated Approving Authority
DDAA	Developmental Designated Approving Authority
DIACAP	DoD Information Assurance Certification and Accreditation Process
DiD	Defense-in-Depth
DISA	Defense Information Systems Agency
DISN	Defense Information Systems Network
DIACAP	DoD Information Assurance Certification and Accreditation Process
DMZ	Demilitarized Zone

Controlled Unclassified Information / FOUO

DREN	Defense Research and Engineering Network
DoD	Department of Defense
DoDD	DoD Directive
DoDI	DoD Instruction
DON	Department of the Navy
DONCIO	Department of the Navy Chief Information Officer
DTM	Directive-Type Memorandum
ECA	External Certificate Authority
E-mail	Electronic Mail
FAM	Functional Area Manager
FIPS	Federal Information Processing Standard
FISMA	Federal Information Security Management Act of 2002
FOUO	For Official Use Only
GIG	Global Information Grid
IA	Information Assurance
IAVA	Information Assurance Vulnerability Alert
IAVB	Information Assurance Vulnerability Bulletin
IAVM	Information Assurance Vulnerability Management
IAVMP	Information Assurance Vulnerability Management Program
IAW	In accordance with
IAWF	Information Assurance Workforce
ICSA	International Computer Security Association
IM	Information Management
INFOCON	Information Operations Condition
IO	Information Officer
ISP	Information Security Program
ISSM/IAM	Information System Security Manager/Information Assurance Manager
ISSO/IAO	Information System Security Officer/Information Assurance Officer
IT	Information Technology
MAC	Mission Assurance Category
MCNOSC	Marine Corps Network Operations Security Center
NACI	National Agency Check with Inquiries
NAVCIRT	Navy computer Incident Response Team

Controlled Unclassified Information / FOUO

NIAP	National Information Assurance Partnership
NETWARCOM	Naval Network Warfare Command
NIAP	National Information Assurance Program
NIPRNET	Non-Classified Internet Protocol Router Network, (Unclass but Sensitive Internet Protocol Router Network)
NISPOM	National Industrial Security Program Operating Manual
NIST	National Institute of Standards and Technology
NMCI	Navy Marine Corps Intranet
NSA	National Security Agency
NSTISSI	National Security Telecommunications and Information Systems Security Instruction
OIC	Officer in Charge
ODAA	Operational Designated Approving Authority
OMB	Office of Management and Budget
OPM	Office of Personnel Management
OPNAV	Office of the Chief of Naval Operations
OPSEC	Operations Security
PDA	Personal Digital Assistant
PEO(T)	Program Executive Officer (Tactical)
PEO(X)	Program Executive Officer X= (Unmanned Aviation and Strike Weapons), or (Assault & Special Missions), or (Strike Weapons and Unmanned Aviation)
PISSM	Program Information System Security Manager
PII	Personally Identifiable Information
PIT	Platform Information Technology
PIT-I	Platform Information Technology Interconnect
PKE	Public Key Enablement
PKI	Public Key Infrastructure
PL	Public Law
PM	Program Manager
NAVAIR	Naval Air Systems Command
POA&M	Plan of Action and Milestones
POC	Point of Contact
SANS	System Administration, Networking, and Security Institute
SBU	Sensitive But Unclassified

Controlled Unclassified Information / FOUO

SECNAV	Secretary of the Navy
SECNAVINST	SECNAV Instruction
SECNAVMAN	SECNAV Manual
SIPRNET	Secure Internet Protocol Routing Network
SNAC	System and Network Attack Center
SOX	Sarbanes-Oxley
SPAWAR	Space and Naval Warfare Systems Command
SSAA	System Security Authorization Agreement
SSL	Secure Sockets Layer
STIG	Security Technical Implementation Guides
STRATCOM	Strategic Command
TASS	Trusted Associate Sponsorship System Consent to Monitor
TLS	Transport Layer Security
USMC	US Marine Corps
USN	US Navy
UTN-P	Unclassified Trusted Network Protection
WAN(s)	Wide Area Network(s)

IA Definitions (per SECNAV M-5239.1)

Accreditation - Formal declaration by the DAA that an information system is approved to operate in a particular security mode using a prescribed set of safeguards at an acceptable level of risk.

Authentication - Authentication is assurance of the identity of a message sender or receiver. Authentication is the security measure designed to establish the validity of a transmission, message, or originator, or a means of verifying an individual's authorization to receive specific categories of information.

Authenticator - The means used to confirm the identity of a station, originator, or individual.

Availability - Availability is assurance of timely, reliable access to data and information systems by authorized users. Availability focused IA controls protect against degraded capabilities and denial of service conditions.

Certification - Comprehensive evaluation of the technical and nontechnical security features of an information system and other safeguards, made in support of the accreditation process, to establish the extent that a particular design and implementation meets a set of specified security requirements.

Class (Control) - IA controls are organized into three classes: management, operational, and technical.

Computer Network Attack - Operations to disrupt, deny, degrade, or destroy information resident in computers and computer networks or the computers and networks themselves.

Confidentiality - Confidentiality is assurance that information is not disclosed to unauthorized persons, processes, or devices. It includes both the protection of operational information and the protection of IA-related system information such as password or configuration files.

Controls - The management, operational, and technical safeguards or countermeasures prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information. Controls also provide authentication and non-repudiation of communications.

Demilitarized Zone - A “screened subnet” that exists logically between the public domain (Internet) and the DISN. This boundary condition can be physical or virtual and is intended to isolate less secure systems and networks.

Enclave - Collection of computing environments connected by one or more internal networks under the control of a single authority and security policy, including personnel and physical security.

Family (Control) - Within each IA control class, individual controls are grouped into families. A family consists of two or more controls designed to accomplish a similar purpose such as Certification and Accreditation or Contingency Planning.

Incident - Assessed occurrence having actual or potentially adverse effects on an information system.(COMSEC) Occurrence that potentially jeopardizes the security of COMSEC material or the secure electrical transmission of national security information or information governed by 10 U.S.C. Section 2315.

Cyber Security - Measures that protect and defend information and information systems by ensuring their availability, integrity, authentication, confidentiality, and no repudiation. These measures include providing for restoration of information systems by incorporating protection, detection, and reaction capabilities.

Information Operations - Actions taken to affect adversary information and information systems, while defending one's own information and information systems. Information Operations require the close, continuous integration of offensive and defensive capabilities and activities, as well as effective design, integration, and interaction of command and control with intelligence support. Information Operations are conducted through the integration of many capabilities and related activities.

Information System - Set of information resources organized for the collection, storage, processing, maintenance, use, sharing, dissemination, disposition, display, or transmission of information.

Information System Security Manager – Individual responsible for the management of the Cyber Security Program.

Information System Security Officer – Individual responsible for the management of a Cyber Security system.

Integrity - Integrity is assurance that information is not modified by unauthorized parties or in an unauthorized manner. Integrity supports the assurance that information is not accidentally or maliciously manipulated, altered, or corrupted. Additionally, integrity implies the ability to detect when information has been altered.

Legacy System - An existing system that is designated for closure when the capability is absorbed by an interim or core system or if the capability is no longer required. No modifications or enhancements are made to legacy systems.

Management Controls - The management class of IA controls addresses topics that may be characterized as managerial. They are techniques and concerns that are normally directed or addressed by leadership. They focus on the management of IA and the management of risk.

Mission Assurance Category - Applicable to all DoD information systems, the mission assurance category reflects the importance of information relative to the achievement of DoD goals and objectives, particularly the warfighters' combat mission. Mission assurance categories are primarily used to determine the requirements for availability and integrity.

Mission Critical (System) - A system the loss of which would cause the stoppage of warfighter operations or direct mission support of warfighter operations.

Mission Essential (System) - A system that is basic and necessary for the accomplishment of the organizational mission.

Mission Support (System) - A system handling information that is important to the support of deployed and contingency forces. It must be absolutely accurate, but can sustain minimal delay without seriously affecting operational readiness or mission effectiveness (may be classified, but is more likely to be sensitive or unclassified).

Net-centricity - Net-centricity is the realization of a networked environment (including infrastructure, systems, processes, and people) that enables a completely different approach to warfighting and business operations. It

compels a shift to a “many-to-many” exchange of data, enabling many users and applications to leverage the same data. This extends beyond the traditional focus on standardized, predefined, point-to point interfaces.

Non-repudiation - Non-repudiation is assurance that the sender of data is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the data.

Operational Controls - The operational class of IA controls focus on activities that are implemented and executed by people as opposed to systems. These controls are put in place to improve the security of a particular system (or group of systems). They often require technical or specialized expertise and rely upon management activities as well as technical controls.

Risk - Possibility that a particular threat will adversely impact an information system by exploiting a particular vulnerability.

Technical Controls - The technical class of IA controls focus on IA controls that are set up by people but executed by systems. To be effective, these controls are dependent upon the proper functioning of the systems. Implementation of technical controls requires significant operational considerations and should be consistent with the management of IA within the organization.

Threat - Any circumstance or event with the potential to adversely impact an information system through unauthorized access, destruction, disclosure, modification of data, and/or denial of service.

Vulnerability - Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited.